

HACKSHIELD CLUB | IIT PATNA

DFIR MASTERCLASS

Day 01: The Foundation of Digital Detectives

A Comprehensive Beginner's Guide to Digital Forensics & Incident Response

Prepared for the Student Technical Council
Level: Beginner | Focus: Theory & Kali Linux Labs

01. Introduction: What exactly is DFIR?

Imagine you walk into your office and find that your server has been encrypted by ransomware, or a database containing thousands of user passwords has been leaked online. What do you do?

Most people think of cybersecurity as **Prevention**—firewalls, passwords, and encryption. But no defense is 100% perfect. **DFIR (Digital Forensics and Incident Response)** is the science of what happens *after* the defense fails.

The Two Sides of the Coin

- **Incident Response (IR):** This is the "Emergency Room" of cyber. When an attack is happening, the IR team moves in to stop the attacker, contain the damage, and get the business back online. It is fast-paced and tactical.
- **Digital Forensics (DF):** This is the "Autopsy." Once the "fire" is out, the forensic team analyzes the data to find out *who* did it, *how* they got in, and *what* they touched. It is slow, meticulous, and scientific.

The Goal: The primary objective of DFIR is not just to "fix the computer," but to identify the root cause of an incident and preserve evidence in a way that could stand up in a court of law.

Why is DFIR critical?

Without DFIR, a company might "fix" a hacked server by simply reinstalling the OS. However, if they don't find the **Root Cause**, the hacker might still have a backdoor in another part of the network, and they will be back tomorrow. DFIR ensures the hacker is truly gone.

02. The Incident Response Lifecycle (PICERL)

Industry professionals don't just "wing it" during a hack. They follow a standardized framework. The most famous is the SANS **PICERL** model. Understanding this is the first step for any beginner.

1. Preparation

The most important phase. You can't fight a fire if you don't have a fire extinguisher. This involves setting up logs, training the team, and having "Forensic Workstations" (like Kali or SIFT) ready to go.

2. Identification

Detecting the "Indicators of Compromise" (IoCs). This is where you realize something is wrong. Maybe a user reports a weird file, or a server is suddenly communicating with an IP address in a foreign country.

3. Containment

Once you find the "sick" computer, you must isolate it so the "virus" doesn't spread. This might mean pulling the network cable or isolating the VM in a separate VLAN. **Crucial:** Don't just turn it off! (We'll explain why in the "Volatility" section).

4. Eradication

Finding the malware, the backdoors, and the stolen credentials and deleting them from the system. You are removing the "cancer" from the network.

5. Recovery

Bringing systems back into production. This is done carefully, usually with extra monitoring to ensure the attacker doesn't try to return immediately.

6. Lessons Learned

The "Post-Mortem." Writing a report on what went wrong and how to prevent it from happening again. This is where the club's documentation skills become vital.

Think like a Lawyer: In DFIR, if you didn't document a step, it never happened. Always keep a timestamped log of every command you run during an investigation.

03. The Fundamental Laws of Forensics

To be a digital forensic investigator, you must understand three core concepts that govern how we handle data.

I. Locard's Exchange Principle

Borrowed from physical criminology, this principle states: *"Every contact leaves a trace."* On a computer, this means an attacker cannot enter a system without changing something. They might leave a record in a log file, change a file's "Last Accessed" time, or leave a remnant in the RAM. Our job is to find those traces.

II. The Order of Volatility (OOV)

Evidence on a computer is not permanent. Some data disappears in milliseconds, while other data stays for years. We must collect the "fast-disappearing" data first.

1. **CPU Cache & Registers:** Disappears in nanoseconds.
2. **RAM (Random Access Memory):** Disappears the moment power is cut. This contains passwords and running malware!
3. **Network State:** Current connections to the internet.
4. **Hard Drive (Disk):** Persistent, but can be overwritten.
5. **Backups & Printouts:** The most stable.

NEVER PULL THE PLUG: Beginners often think "Turn it off to stop the hacker!" But if you turn off a computer, you kill the RAM and the Network state—destroying 90% of your best evidence.

III. Chain of Custody

This is a roadmap of who touched the evidence, when they touched it, and what they did. If you analyze a hard drive and cannot prove that *only you* had access to it, your findings will be thrown out of court.

04. Hands-On Lab: Live Triage on Kali Linux

Now, let's put theory into practice. We are going to perform "Live Triage." This is the act of collecting volatile data from a running system that might be compromised.

Step 1: Assessing the Environment

First, we need to know who is on our "crime scene." Run these commands in your Kali terminal.

Checking Logged-in Users:

```
who -u
```

Search for users you don't recognize or users logged in from unusual IP addresses.

Checking System Uptime:

```
uptime
```

Knowing how long a system has been running helps you determine how far back your RAM and logs might go.

Step 2: Network Forensics (Live)

Hackers usually need a "Call Home" connection to control the machine. We use **ss** (Socket Statistics) to find them.

```
ss -tulpn
```

What to look for: Look for "ESTABLISHED" connections to ports like 4444 (common for Metasploit) or unusual high-numbered ports talking to external IPs.

Step 3: Process Analysis

Malware runs as a "Process." We need to see if any process looks "shady."

```
ps auxf
```

The **f** flag shows a tree view. Look for a process that has no "Parent" or a process running with **root** privileges that shouldn't be (like a web browser).

05. Digging into the Logs

Logs are the "Black Box" of a computer. On Linux, almost all forensics starts in the `/var/log` directory.

Task: Investigating Authentication

The file `/var/log/auth.log` records every time someone tries to log in or uses `sudo`. This is the first place to look for "Brute Force" attacks.

View the last 20 login attempts:

```
sudo tail -n 20 /var/log/auth.log
```

Searching for Failed Logins:

```
grep "Failed password" /var/log/auth.log
```

If you see hundreds of failed attempts from the same IP, you've found a Brute Force attack!

06. Day 01 Summary & Challenge

Today you learned that DFIR is about evidence preservation and methodical investigation. You learned the PICERL lifecycle and practiced basic triage on Kali.

The "Ghost File" Challenge

1. Open a terminal and create a file: `echo "Hacked by Club" > evidence.txt`

2. Now, delete it: `rm evidence.txt`

3. **The Mission:** Use the command `journalctl | grep "evidence.txt"` . Can you find any record of that file being mentioned by the system?

Even when a file is gone, the system often remembers. Welcome to the world of forensics.